

Penetration Test Report

Target: DVWA (Damn Vulnerable Web Application)



Table Concept

1. Executive Summary	1
2. Scope	2
3. Methodology	3
4. Vulnerabilities identified	4
4.1 SQL injection(SQLi)	5
4.2 Cross - site scripting (XSS) - Reflected	6
4.3 Cross - site scripting (XSS) - stored	7
4.4 Command injection	8
4.5 File Inclusion (LFI)	9
4.6 Weak Authentication (Brute Force)	10
5 Summary of Findings	11
6 Recommendations	12
7 Appendix	13

1. Executive Summary

This penetration test was conducted on the **Damn Vulnerable Web Application (DVWA)**, a deliberately insecure PHP/MySQL web application designed for testing web security tools and training. The primary objective was to identify and exploit common web vulnerabilities to demonstrate their risk and provide remediation guidance.

2. Scope

- **Target:** DVWA instance running on <http://localhost/dvwa>
- **Testing Levels:** Low, Medium, High (Impossible excluded for demonstration)
- **Test Type:** White-box (source code was available)
- **Tools Used:** Burp Suite, OWASP ZAP, sqlmap, Nikto, Nmap, Tools

3. Methodology

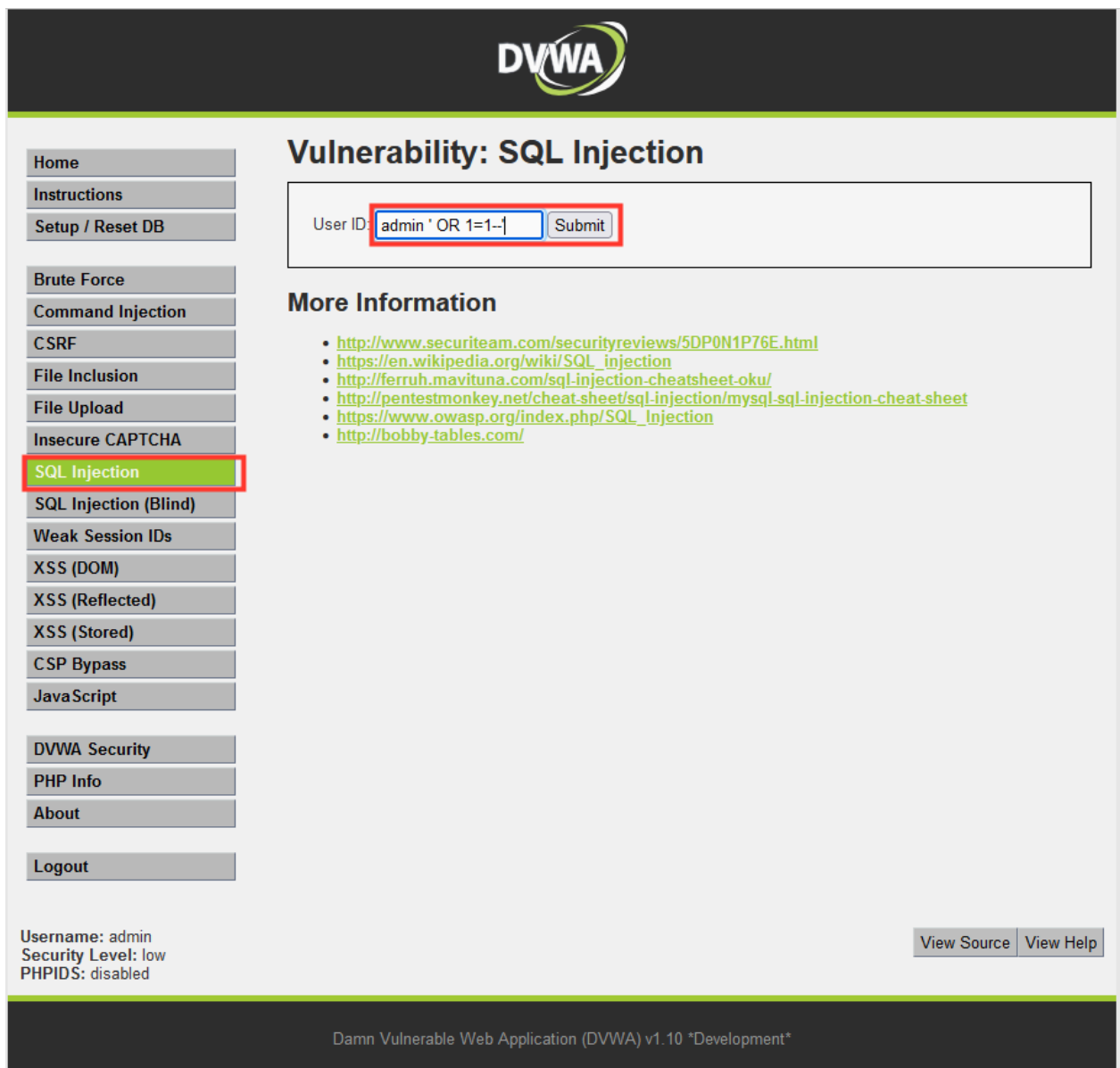
Testing followed the OWASP Testing Guide (v4) and focused on:

- Reconnaissance
- Vulnerability Identification
- Exploitation
- Reporting and Remediation Suggestions

4. Vulnerabilities Identified

4.1 SQL Injection (SQLi)

- Page: `vulnerabilities/sqli/`
- Severity: High
- Vector: `' OR '1'='1`



The screenshot displays the DVWA web application interface. At the top, the DVWA logo is visible. The main heading is "Vulnerability: SQL Injection". Below this, there is a form for "User ID" with the input field containing the payload `admin ' OR 1=1--|` and a "Submit" button. To the left of the main content is a sidebar menu with various vulnerability categories. The "SQL Injection" category is highlighted with a red box. Below the "More Information" section, there is a list of links to external resources. At the bottom of the page, the username "admin" and security level "low" are displayed, along with a "View Source" and "View Help" button.

Vulnerability: SQL Injection

User ID:

More Information

- <http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
- https://en.wikipedia.org/wiki/SQL_injection
- <http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/>
- <http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>
- https://www.owasp.org/index.php/SQL_injection
- <http://bobby-tables.com/>

Username: admin
Security Level: low
PHPIDS: disabled

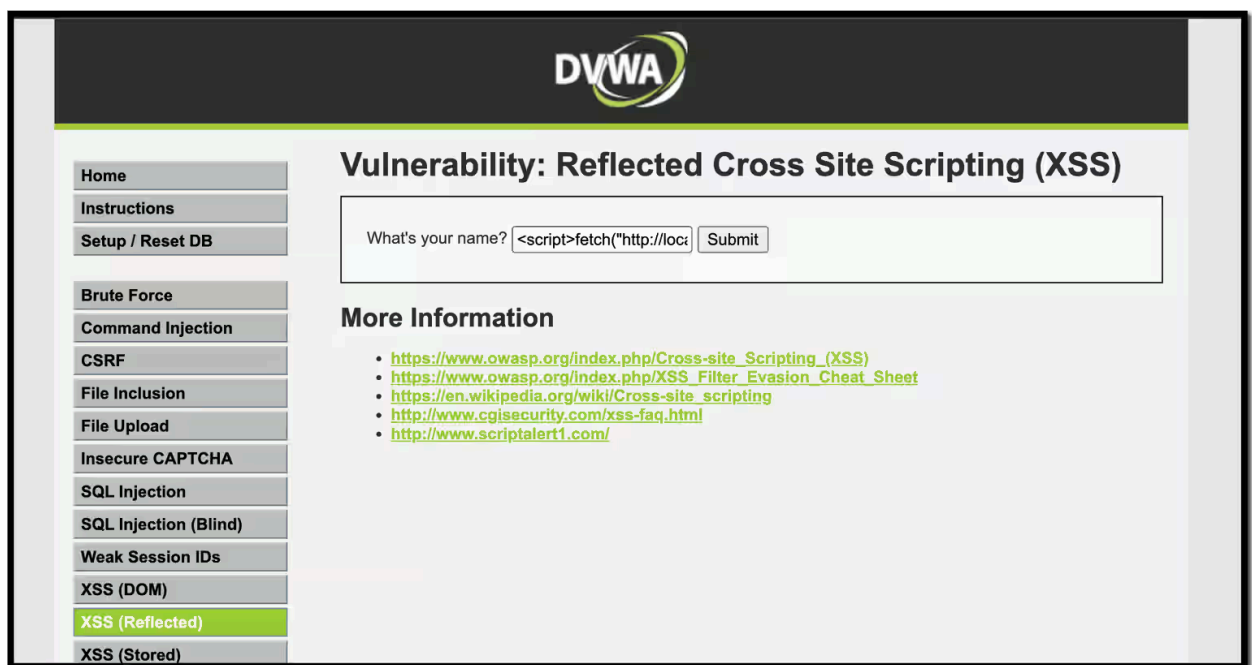
[View Source](#) [View Help](#)

Damn Vulnerable Web Application (DVWA) v1.10 *Development*

- **Impact:** Unauthorized data disclosure
- **Exploit:** sqlmap used to extract user credentials
- **Recommendation:** Use parameterized queries (e.g., PDO or prepared statements)

4.2 Cross-Site Scripting (XSS) - Reflected

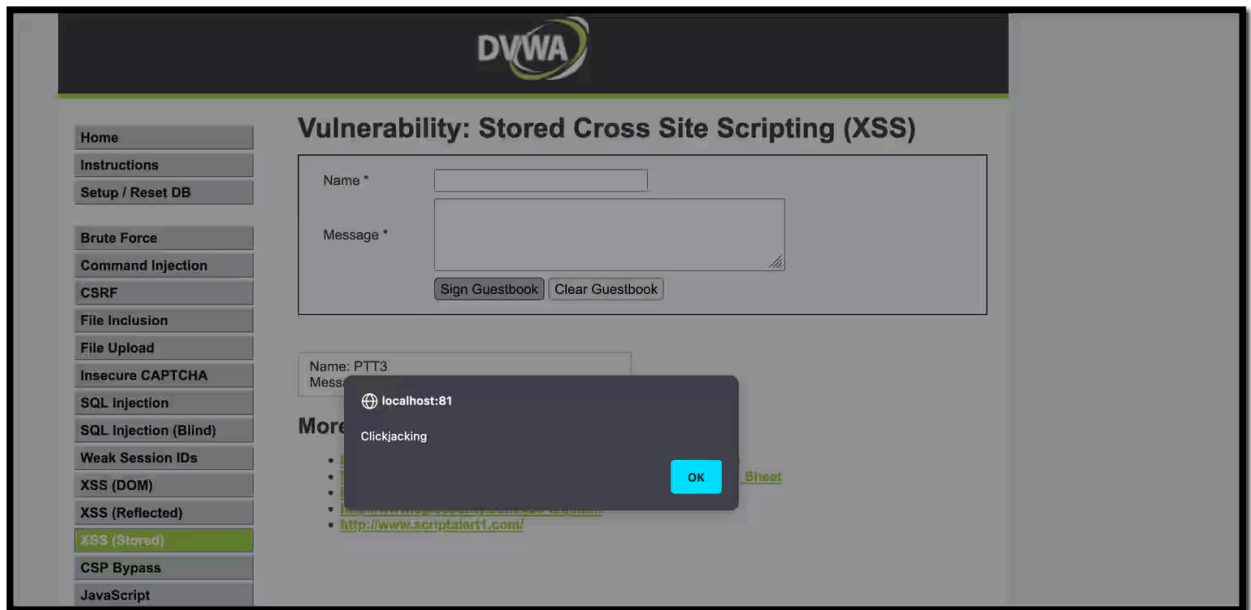
- **Page:** `vulnerabilities/xss_r/`
- **Severity:** Medium
- **Vector:** `<script>alert('XSS')</script>`



- **Impact:** Session hijacking, phishing
- **Recommendation:** Sanitize input and encode output

◆ 4.3 Cross-Site Scripting (XSS) - Stored

- **Page:** [vulnerabilities/xss_s/](#)
- **Severity:** High
- **Vector:** `<script>document.cookie</script>`



- **Impact:** Persistent session compromise
- **Recommendation:** Implement proper output encoding and CSP headers

4.4 Command Injection

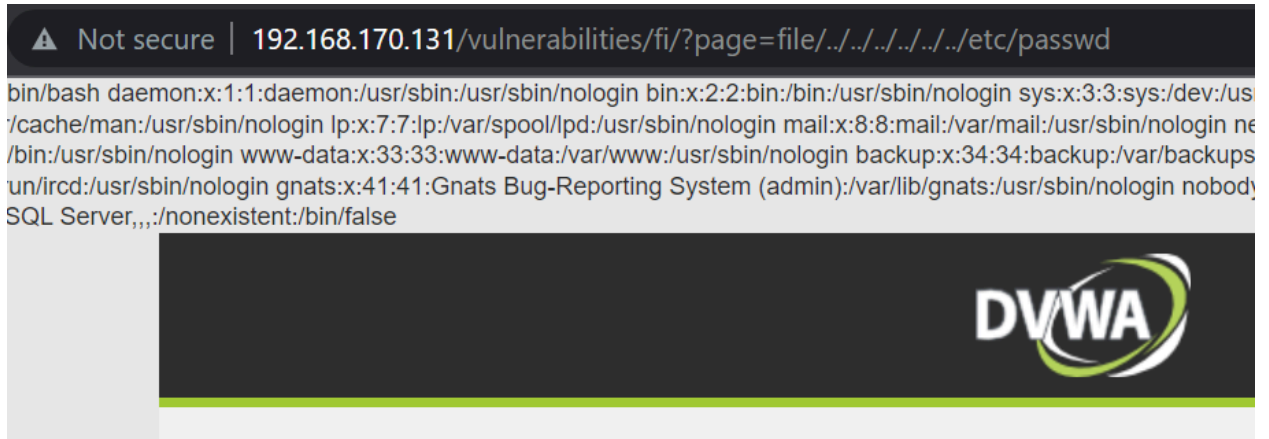
- **Page:** [vulnerabilities/exec/](#)
- **Severity:** High

- **Vector:** `127.0.0.1; cat /etc/passwd`

- **Impact:** Arbitrary command execution
- **Recommendation:** Use `escapeshellcmd()` or avoid shell commands altogether

4.5 File Inclusion (LFI)

- **Page:** `vulnerabilities/fi/?page=../../../../../../etc/passwd`



- **Severity:** Critical
- **Impact:** Arbitrary file read
- **Recommendation:** Validate and whitelist file paths

4.6 Weak Authentication (Brute Force)

- Page: `vulnerabilities/brute/`

The screenshot displays the DVWA (Damn Vulnerable Web Application) interface. The browser's address bar shows the URL `192.168.56.101/dvwa/vulnerabilities/brute/?username=`. The page title is "Vulnerability: Brute Force". On the left, a sidebar contains navigation links: Home, Instructions, Setup, Brute Force (highlighted), Command Execution, CSRF, Insecure CAPTCHA, File Inclusion, SQL Injection, SQL Injection (Blind), Upload, XSS reflected, XSS stored, DVWA Security, PHP Info, About, and Logout. The main content area features a "Login" form with "Username:" and "Password:" labels, input fields, and a "Login" button. Below the form, a red error message reads "Username and/or password incorrect." Under the "More info" section, three links are provided: http://www.owasp.org/index.php/Testing_for_Brute_Force_%28OWASP-AT-004%29, <http://www.securityfocus.com/infocus/1192>, and <http://www.sillychicken.co.nz/Security/how-to-brute-force-http-forms-in-windows.html>. At the bottom left, the current session information is shown: "Username: user", "Security Level: low", and "PHPIDS: disabled". At the bottom right, there are "View Source" and "View Help" buttons. The footer at the very bottom states "Damn Vulnerable Web Application (DVWA) v1.8".

- **Severity:** Medium
- **Impact:** Unauthorized access
- **Recommendation:** Implement account lockout and CAPTCHA

5. Summary of Findings

Vulnerability	Risk Level	Affected Module
SQL Injection	High	Login, SQLi Page
Reflected XSS	Medium	XSS Reflected
Stored XSS	High	XSS Stored
Command Injection	High	Command Execution
Local File Inclusion	Critical	File Inclusion
Brute Force	Medium	Authentication

6. Recommendations

- Enforce **input validation** and **output encoding**
- Apply **principle of least privilege** on the web server
- Deploy **Web Application Firewalls (WAF)**
- Use **HTTPS** even in test environments
- Regular **code reviews** and **penetration testing**

7. Appendix

- **Payloads Used**
- **Screenshots of Exploits**
- **Tool Output Logs (sqlmap, Burp Suite, etc.)**

